

Your Events App

Full Test Plan — Role-Tagged Checklist

Prepared June 19, 2026 · Production: <https://www.yourevents.app>

How to use this checklist

Tick each box as you complete the test. Every item is tagged with the role that performs it. Run the Golden-Path Flow first as a smoke test, then work through sections A–J for depth. Record any failure with its ID, the steps, and actual vs expected.

Role legend

- [Attendee] the public registrant / signed-in attendee account
- [Organizer] event host (also ADMIN) managing events in the dashboard
- [Staff/Volunteer] event team with check-in access only
- [SUPERADMIN] platform admin (you / AITS)
- [Public/Tester] unauthenticated visitor or system/worker-driven checks

Prerequisites

- Stripe test mode — card 4242 4242 4242 4242 (decline: 4000 0000 0000 0002).
- A Connect-onboarded organization (paid tickets are blocked until Charges are enabled).
- The worker service running (waitlist promotion, reminders).
- RESEND_API_KEY set (every email test depends on it).
- Two browser contexts — normal (organizer/staff) and incognito (attendee/public).
- 2–3 email inboxes you control for attendee/organizer/second-attendee.
- An authenticator app (Google Authenticator / Authy / 1Password) for the MFA tests.

0. Golden-Path Flow (run first)

One end-to-end pass exercising the core lifecycle. If all ten steps pass, the app is fundamentally healthy.

- [] [Organizer] **Step 1.** Organizer signs up at /signup and lands in the dashboard
- [] [Organizer] **Step 2.** Create a paid event, add a \$1 ticket, a custom question, then Publish
- [] [Organizer] **Step 3.** Create a promo code (TEST10, 10% off)
- [] [Attendee] **Step 4.** In incognito, register, apply TEST10, confirm discount, pay with 4242...
- [] [Attendee] **Step 5.** Success page shows QR + account prompt; confirmation email has QR + ICS + sign-in link
- [] [Attendee] **Step 6.** Sign in via /account/signin magic link; /account shows the registration
- [] [Staff/Volunteer] **Step 7.** Check the attendee in at /checkin (scan or manual token)
- [] [Attendee] **Step 8.** Request a refund from /account or the email link
- [] [Organizer] **Step 9.** Approve the refund request; attendee gets the decision email; /account shows REFUNDED + date
- [] [Organizer] **Step 10.** Confirm /dashboard/financials reflects the sale and the refund correctly

A. Authentication & accounts

- [] [Organizer] **A1 — Organizer signup**
/signup with email, password (8+), name, org, slug -> Account + org created; lands in dashboard
- [] [Organizer] **A2 — Organizer sign-in**
/signin with correct credentials -> Lands in /dashboard
- [] [Organizer] **A3 — Bad sign-in**
/signin with wrong password -> Generic 'Invalid credentials'; constant response time
- [] [Organizer] **A4 — Forgot password request**
/signin > Forgot password? > enter org email -> Generic 'check your inbox'; reset email arrives
- [] [Organizer] **A5 — Reset password**
Click email link > set new password (confirm) > sign in -> Old password rejected; new one works
- [] [Organizer] **A6 — Reset link reuse/expiry**
Use the same link twice / after 15 min -> Invalid or expired
- [] [Organizer] **A7 — Staff invite**
Dashboard > Team > invite a staff/volunteer email -> Invite email arrives with accept link
- [] [Staff/Volunteer] **A8 — Accept invite**
Open invite link > set password -> Account at invited role; can sign in

- [] **[Staff/Volunteer] A9 — Staff destination**
Sign in as STAFF or VOLUNTEER -> Lands on /checkin, not /dashboard
- [] **[Attendee] A10 — Magic-link request**
/account/signin > enter email > send link -> Generic 'check your inbox'; magic-link email arrives
- [] **[Attendee] A11 — Attendee sign-in**
Click magic link -> Lands on /account; link single-use (second click fails)
- [] **[Attendee] A12 — Guest backfill**
Register as guest, then sign in with that email -> Past registration appears in /account
- [] **[Attendee] A13 — Gate: attendee to dashboard**
Signed-in attendee visits /dashboard -> Redirected to /account
- [] **[Organizer] A14 — Gate: staff to account**
Signed-in organizer/staff visits /account -> Redirected to /dashboard
- [] **[Organizer] A15 — Gate: non-super to admin**
Non-SUPERADMIN visits /admin -> Redirected to /dashboard
- [] **[Public/Tester] A16 — No account enumeration**
Magic-link/forgot for a non-existent email -> Same generic success; no email; no error revealing absence
- [] **[Organizer] A17 — Enable MFA (TOTP)**
Dashboard > Settings > enable MFA; scan the QR in an authenticator app; confirm the 6-digit code -> MFA enabled; 10 single-use recovery codes shown once
- [] **[Organizer] A18 — MFA login challenge**
Sign out, then sign in again with MFA enabled -> Prompted for a 6-digit code; the correct code lands in the dashboard
- [] **[Organizer] A19 — MFA recovery code**
At the code prompt, enter a recovery code instead of the app code -> Signs in; that recovery code cannot be reused
- [] **[Organizer] A20 — Disable MFA**
Settings > disable MFA (confirm with a code) -> MFA off; next sign-in needs no code
- [] **[Staff/Volunteer] A21 — Staff is password-only**
As a STAFF/VOLUNTEER email, request a magic link / open one -> Blocked to /signin?error=use_password; only password sign-in works
- [] **[Organizer] A22 — Role-based session length**
Sign in; inspect the session cookie Max-Age -> ~12h for organizer/staff, ~7d for attendee

B. Event management

- [] **[Organizer] B1 — Create free event**
New event > Free tier -> Created as draft
- [] **[Organizer] B2 — Create premium event**
New event > Single Event (1 credit) -> Credit decremented; event isPremium
- [] **[Organizer] B3 — Edit basics**
Edit name/dates/timezone > save -> Saved; public page updated; times in event tz
- [] **[Organizer] B4 — Banner image**
Set banner URL/upload -> Shows on public event page
- [] **[Organizer] B5 — Add free ticket**
Add ticket type, price 0 -> Created as FREE
- [] **[Organizer] B6 — Paid ticket without Connect**
Non-Connect org adds a paid ticket -> Blocked (payouts_required)
- [] **[Organizer] B7 — Add paid ticket**
Connect-ready org adds paid ticket + qty -> Created with quantity
- [] **[Organizer] B8 — Custom questions**
Add required + optional questions -> Appear on form; required enforced
- [] **[Organizer] B9 — Presale / early-bird**
Set presale percent + end datetime -> Active badge; public banner; auto-discount before cutoff
- [] **[Organizer] B10 — Promo code: percentage**
Promo codes page > SAVE20, 20% off -> Listed ACTIVE; usage 0 / limit
- [] **[Organizer] B11 — Promo code: fixed**
FLAT5, fixed \$5 off -> Listed; shows '\$5.00 off'
- [] **[Organizer] B12 — Promo code: usage limit**
Set limit 1, redeem once -> Second use rejected at checkout
- [] **[Organizer] B13 — Promo code: expiry**
Set expiry in the past -> Shows EXPIRED; rejected at checkout

- [] **[Organizer] B14 — Promo code: activate/deactivate**
Toggle a code inactive then active -> Inactive rejected; reactivation works
- [] **[Organizer] B15 — Promo code: delete vs deactivate**
Delete unused (works); delete redeemed (blocked) -> Redeemed shows 'deactivate instead'
- [] **[Organizer] B16 — Promo code: duplicate**
Two codes same name on one event -> Second blocked
- [] **[Organizer] B17 — Publish / unpublish**
Toggle publish -> Public page reachable/hidden; private excluded from /api/events
- [] **[Organizer] B18 — Upgrade free to premium**
Free event > Upgrade to Single Event -> Credit spent; premium features unlock
- [] **[Organizer] B19 — Action grid layout**
View event page on desktop + mobile -> Uniform grid (2 rows desktop), equal box sizes
- [] **[Organizer] B20 — Event QR code**
Event page > QR code (between Communications and Export CSV) > opens a popup window -> QR points to the public event page; Copy / Close / Download PNG work; scanning opens registration

C. Public registration & payment

- [] **[Attendee] C1 — Free registration**
Register for a free event -> CONFIRMED immediately; QR; confirmation email
- [] **[Attendee] C2 — Paid registration**
Register, pay with 4242... -> Stripe > success; CONFIRMED after webhook; email
- [] **[Attendee] C3 — Declined card**
Pay with 4000 0000 0000 0002 -> Payment fails; no confirmed reg; seat not consumed
- [] **[Attendee] C4 — Promo at checkout**
Enter a valid % code -> Discount line shows; charge equals shown total
- [] **[Attendee] C5 — Promo stacks with early-bird**
Active presale + valid promo -> Both apply (promo on post-presale price)
- [] **[Attendee] C6 — Invalid promo**
Enter bad/expired/used code -> Inline error; totals fall back to no-promo
- [] **[Attendee] C7 — Address fields**
Fill address on registration -> Stored; appears in CSV export
- [] **[Attendee] C8 — Duplicate confirmed email**
Register same email twice -> Second blocked with friendly message
- [] **[Attendee] C9 — Capacity enforcement**
Two buyers for the last seat -> No oversell; second sees sold-out
- [] **[Attendee] C10 — Confirmation email contents**
Check inbox after C1/C2 -> QR + ICS + refund link + account sign-in link
- [] **[Attendee] C11 — Tickets behind key**
Open success page with/without ?key= -> Hidden without key; shown with correct key
- [] **[Organizer] C12 — Reissue tickets**
Registrations > Reissue on a confirmed registration -> 'Tickets reissued' banner; fresh confirmation email with a working QR

D. Waitlist

- [] **[Attendee] D1 — Sold-out shows waitlist**
Sell out an event, view public page -> Sold-out notice + waitlist form (if enabled)
- [] **[Attendee] D2 — Join waitlist**
Submit name/email -> 'You're on the waitlist! Position #N'; leave link
- [] **[Attendee] D3 — Duplicate waitlist**
Join again same email -> Blocked (already on waitlist)
- [] **[Attendee] D4 — Auto-promotion (worker)**
Free a seat; wait ~5 min for worker -> Next person PROMOTED; promotion email sent
- [] **[Attendee] D5 — Magic-link claim**
Click 'Claim your spot' in email -> Register page prefilled; bypasses sold-out
- [] **[Attendee] D6 — CONVERTED**
Complete the claim registration -> Waitlist entry flips to CONVERTED
- [] **[Attendee] D7 — Leave waitlist**
Click 'Leave the waitlist' -> Status LEFT; confirmation page

- [] **[Public/Tester] D8 — Promotion expiry (worker)**
Let a PROMOTED entry pass 24h -> Worker flips to EXPIRED
- [] **[Organizer] D9 — Organizer waitlist view**
/dashboard/events/[id]/waitlist -> Status counts + ordered queue

E. Check-in

- [] **[Staff/Volunteer] E1 — QR scan**
/checkin > scan a valid ticket -> Checked in; shows attendee
- [] **[Staff/Volunteer] E2 — Manual entry**
Paste the QR token -> Same as scan
- [] **[Staff/Volunteer] E3 — Double scan**
Scan same ticket twice -> Second > ALREADY_USED
- [] **[Staff/Volunteer] E4 — Wrong-org ticket**
Scan a ticket from another org -> Rejected (org-scoped)
- [] **[Staff/Volunteer] E5 — Cancelled/refunded ticket**
Scan a refunded/cancelled ticket -> Invalid
- [] **[Staff/Volunteer] E6 — Scanner resilience**
Deny camera / no BarcodeDetector -> Fallback notice; manual entry works

F. Refunds

- [] **[Organizer] F1 — Organizer net refund**
Registrations > Refund (net) -> Ticket minus 4.5%; REFUNDED; seat released
- [] **[SUPERADMIN] F2 — SUPERADMIN full refund**
As SUPERADMIN, Refund > Full (100%) -> Full amount incl. fee returned
- [] **[Organizer] F3 — Organizer cannot full-refund**
As ORGANIZER, attempt full refund -> Forbidden (server-enforced); only net
- [] **[Organizer] F4 — Bulk refund**
Select multiple regs > Refund selected -> Each processed; result banner counts
- [] **[Organizer] F5 — Vendor refund**
Vendors page > Refund vendor (net/full) -> Vendor booth refunded consistently
- [] **[Attendee] F6 — Customer refund request**
/account or email > Request refund + reason -> OPEN request; organizer notified by email
- [] **[Organizer] F7 — Organizer approve**
Refund requests page > Approve -> Net Stripe refund; attendee gets approved email
- [] **[Organizer] F8 — Organizer deny**
Approve another as Deny + note -> DENIED; attendee gets decision email with note
- [] **[Attendee] F9 — Duplicate request**
Submit a second request while one is OPEN -> Blocked (409)
- [] **[Attendee] F10 — Refund shows in account**
After F1/F7, open /account -> Card shows 'Refunded \$X on DATE'
- [] **[Organizer] F11 — Refund finance correctness**
After a net refund, check /dashboard/financials -> Refunded ticket = \$0 organizer revenue/net/payout

G. Financials & exports

- [] **[Organizer] G1 — Organizer financials**
/dashboard/financials -> Revenue, payout, fees, refunds, promo, tax; chart; per-event
- [] **[Organizer] G2 — Time-range filter**
Switch 1D/1W/1M/All + custom -> Metrics + chart rescope
- [] **[Organizer] G3 — Per-event financials**
Event page Financials section -> Per-ticket-type breakdown matches totals
- [] **[Organizer] G4 — Registrations CSV**
Export CSV > Registrations -> Includes address + custom Qs; no formula injection
- [] **[Organizer] G5 — Vendors CSV**
Export CSV > Vendors -> Includes vendor + address columns
- [] **[SUPERADMIN] G6 — Platform financials**
/admin/financials -> Net GMV, fee revenue, MRR/ARR, leaderboard, disputes

H. Communications & emails

- [] **[Attendee] H1 — Confirmation email**
Register (see C10) -> Sent on confirm; EmailLog SENT
- [] **[Attendee] H2 — Reminder emails (worker)**
Event starting soon; worker runs -> Reminder once per window; no duplicates
- [] **[Organizer] H3 — Campaign / broadcast**
Communications > send a campaign -> Recipients receive; send button shows pending
- [] **[Organizer] H4 — Refund notifications**
Trigger request + decision (F6-F8) -> Organizer alerted on request; attendee on decision
- [] **[Attendee] H5 — Waitlist promotion email**
Trigger D4 -> Email with claim + leave links
- [] **[Organizer] H6 — Magic-link / reset emails**
Trigger A4 / A10 -> From platform sender; links use www.yourevents.app
- [] **[Attendee] H7 — Email escaping**
Register with a name containing -> Email shows literal text, not injected HTML

I. Admin (SUPERADMIN)

- [] **[SUPERADMIN] I1 — Org list / manage**
/admin > org > Manage -> Org details + subscription editor + overrides
- [] **[SUPERADMIN] I2 — Subscription editor**
Set plan/status/credits/overrides -> Saved; audit log; reflected in enforcement
- [] **[SUPERADMIN] I3 — Connect reset**
'Reset Stripe Connect' on an org -> stripeAccountId nulled; org can re-onboard
- [] **[SUPERADMIN] I4 — Subscription re-sync**
'Re-sync from Stripe' -> Pulls live subscription status
- [] **[SUPERADMIN] I5 — Platform financials**
/admin/financials -> Platform-wide metrics

J. Cross-cutting / non-functional

- [] **[Public/Tester] J1 — Mobile responsiveness**
Resize to phone width on public + dashboard -> Layouts adapt; action grid stacks to 2 cols
- [] **[Public/Tester] J2 — API error shape**
Hit a protected API while signed out -> JSON 401/403, not HTML 500
- [] **[Public/Tester] J3 — Rate limiting**
Spam magic-link/forgot/waitlist -> After limit, still generic 200, no abuse
- [] **[Organizer] J4 — Private events hidden**
Mark an event private -> Excluded from /api/events and homepage
- [] **[Public/Tester] J5 — Redis outage tolerance**
Stop Redis (if possible) -> Rate limiting fails open; sign-in/check-in work
- [] **[Public/Tester] J6 — Sentry capture**
Trigger a server error -> Event in Sentry (traces minified until token set)
- [] **[Public/Tester] J7 — Three login doors**
Homepage header -> Attendee / Organizer & staff / Sign up route correctly
- [] **[Public/Tester] J8 — Footer links resolve**
Footer (homepage + any marketing page) > click each link -> How it works / Pricing / Help / Contact / Status / About / Security / Terms / Privacy all load (no 404)
- [] **[Public/Tester] J9 — Pricing & fees page**
Visit /pricing -> Free + \$19 plans; 'Fees on paid ticket sales & vendors' shows 4.5% + 2.9% + \$0.30; free/\$0 fee-free
- [] **[Public/Tester] J10 — Security page**
Visit /security -> 'Security & compliance' page lists TLS, PCI via Stripe, MFA, signed QR, etc.

Regression checklist (after any deploy)

- [] Homepage loads; three login buttons route correctly
- [] Organizer can sign in; attendee magic link works end to end
- [] Public event page loads; free + paid registration completes
- [] Confirmation email arrives with QR
- [] Check-in scans a fresh ticket

- [] Organizer financials render without error
- [] Event QR code button opens the popup and points to the public event page
- [] Footer links all resolve (no 404)
- [] No 0.0.0.0:8080 or redirect-loop errors on any auth redirect

Out of scope (do not file as bugs)

- Partial (arbitrary-amount) refunds — only full and net-minus-fee exist
- Sentry source-map upload (traces minified until token added)
- Promo code start-time gating (only expiry is enforced)
- Legacy /events/[slug] cross-org slug ambiguity (/o/[orgSlug] is canonical)

